

IR Triage Report

Front Matter

ANALYST NAME: Michelle Vera Rodriguez

DATE: 07/06/2025

SOURCE: security@0x2asec.com

ALERT ID: UR-INT-20250603-0047

SEVERITY: HIGH ▾

DISPOSITION: True Positive (TP) ▾

Initial Findings

We have two types of attacks : an APT and the other one is ransomware.

They visited www.imreallynotbatman.com, and some of the reports reference “P01s0n1vy.” In case you are unaware, P01s0n1vy is an APT group that has targeted Wayne Enterprises

The incident concerning host we8105desk is associated with a Cerber ransomware infection.

True Positive for both APT and ransomware attacks signifies that your security measures are functioning effectively in detecting and alerting on genuine threats, allowing your team to take appropriate action.

High severity: APTs often exfiltrate sensitive data before deploying ransomware, using it as leverage for double or triple extortion tactics. This increases the pressure on the victim organization to pay the ransom.

Incident Summary

imreallynotbatman.com total time range and duration of incident

Incident activity was observed between 2016-08-10T15:37:16.465308-0600 to 2016-08-10T22:21:49.019309, spanning a total duration of approximately 6 hours and 44 minutes. For host we8105desk an initial **solidaritedeproximate.org** is the first suspicious domain visited by we8105desk on 2016-08-24T16:48:12.267.

2016-08-10T16:19:11.351981 **/poisonivy-is-coming-for-you-batman.jpeg** is the filename associated with the file used to deface the imreallynotbatman.com website.

2016-08-10T21:36:48.121938 **40.80.148.42** We can assume that due to the volume of traffic, this source ip is scanning our server.

2016-08-10T21:46:48.574820 **23.22.63.114** IP address the threat actor linked to domains that were preconfigured (“pre-staged”) for an attack on Wayne Enterprises.

2016-08-10T21:52:45.437445 **3791.exe** the name of the executable uploaded by P01s0n1vy

2016-08-10T22:19:10.438743 the fully qualified domain name (FQDN) was used in this attack to resolve to the malicious IP address via dynamic DNS is **prankglassinebracket.jumpingcrab.com**

2016-08-10 21:45:21.226 the first password attempted in the attack **12345678**

2016-08-10T21:45:18.889296 **yellow** is one of the passwords in the brute force attack that is Coldplay's favorite song.

2016-08-10T22:22:27.614541 Looking at the dest_headers we can see that **Joomla** is likely to be the CMS in use.

2016-08-24T10:48:14.620665 **mhtr.jpg** is The malware downloads a file that contains the Cerber ransomware cryptor code.

2016-08-24T16:48:12.267 **solidaritedeproximate.org** the first suspicious domain visited by we8105desk

2016-08-24T17:15:12.668 cerberhhyed5frqa.xmfir0.win is the Fully qualified domain name (FQDN) that the Cerber ransomware attempts to direct the user to at the conclusion of its encryption phase

2016-08-24T22:42:17.287 we can say that an USB key was inserted into the infected machine called **MIRANDA_PRI**

imreallynotbatman.com

- **Attack Stages:** The incident follows a typical cyber kill chain model, including Reconnaissance, Exploitation (Brute-force attack), Installation (of malware), and Action on Objective (Website defacement).
- **Reconnaissance:** This stage involved scanning the webserver (imreallynotbatman.com) using a vulnerability scanner, Acunetix, from the IP address 40.80.148.42.
- **Exploitation:** Brute force attacks were successfully conducted against the web server.
- **Website Defacement:** The attackers defaced the website, leaving a message saying "YOUR SITE HAS BEEN DEFACED".
- **Evidence of Malware:** The analysis points towards the possibility of malware being downloaded and installed on the server.

we8105desk

- **Date:** The attack occurred on August 24th, 2016.
- **Host:** The compromised machine was a Windows 10 workstation named we8105desk, used by an individual named Bob Smith.
- **Cause:** Bob Smith found a USB drive and plugged it into his desktop, opening a malicious word document titled "MIRANDA_PRI". This initiated the Cerber ransomware infection.
- **Impact:** The ransomware caused speakers to blare, changed the desktop image, and rendered files inaccessible.
- **File server involvement:** Bob Smith's workstation was connected to a file server during the incident, and file sharing could have been leveraged to encrypt shared data, escalating the impact of the attack.
- **IP Address of we8105desk:** The most likely IP address of we8105desk on August 24, 2016, was 192.168.250.100.

Ingress Tool Transfer (T1105): The custom malware attached to spear phishing emails is likely connected to the adversary's initial attack infrastructure, indicating the use of this technique. <https://attack.mitre.org/techniques/T1105/>

Application Layer Protocol (T1071): This exfiltration method relies on the application layer protocol HTTPS. <https://attack.mitre.org/techniques/T1071/>

User Executio (T1204): An adversary may rely upon specific actions by a user in order to gain execution. Users may be subjected to social engineering to get them to execute malicious code by, for example, opening a malicious document file or link. <https://attack.mitre.org/techniques/T1204/>

Data Encrypted for Impact:In the case of ransomware(T1486): it is typical that common user files like Office documents, PDFs, images, videos, audio, text, and source code files will be encrypted (and often renamed and/or tagged with specific file markers). <https://attack.mitre.org/techniques/T1486/>

Recommended Actions

IR-related actions for impacted infrastructure

- **Establish a dedicated Incident Response Team:** Ensure the team is well-trained and equipped with the necessary tools and expertise to handle APT and ransomware attacks.
- **Develop a comprehensive Incident Response Plan:** This plan should specifically address APT and ransomware attacks, outlining roles, responsibilities, communication protocols, and recovery steps.

Prevention-related recommended actions for impacted infrastructure

Behavior Prevention on Endpoint: refers to the use of technologies and strategies to detect and block potentially malicious activities by analyzing the behavior of processes, files, API calls, and other endpoint events. Rather than relying solely on known signatures, this approach leverages heuristics, machine learning, and real-time monitoring to identify anomalous patterns indicative of an attack.

<https://attack.mitre.org/mitigations/M1040/>

Network Intrusion Prevention: Use intrusion detection signatures to block traffic at network boundaries.

<https://attack.mitre.org/mitigations/M1031/>

Data Backup: involves taking and securely storing backups of data from end-user systems and critical servers. It ensures that data remains available in the event of system compromise, ransomware attacks, or other disruptions. <https://attack.mitre.org/mitigations/M1053/>

Prevention-related recommended actions for internal

Employee Training and Awareness:

- **Security Awareness Training:** Conduct regular training on cybersecurity best practices, including recognizing and avoiding phishing attacks, using strong passwords, and safe browsing habits.
- **Phishing Simulations:** Simulate phishing attacks to test employees' ability to identify and respond appropriately.
- **Suspicious Email Policies:** Establish clear guidelines for handling suspicious emails, including instructions for reporting potential phishing attempts.

Email Security:

- **Email Filtering and Spam Protection:** Employ robust email security solutions to filter out spam and potentially malicious emails.
- **Sender Authentication:** Utilize SPF, DKIM, and DMARC to verify email sender legitimacy and prevent email spoofing.
- **Be Cautious with Attachments and Links:** Train employees to be wary of attachments and links from unknown senders and to verify their legitimacy.

Detection-related recommended actions for improved SOC flows

Optimize SOC Workflows and Incident Response:

- Automate Repetitive Tasks: Reduce manual effort on tasks like data collection and log analysis to free up analysts for higher-value activities.
- AI-Driven Triage: Implement AI and machine learning for prioritizing alerts based on severity, reducing false positives and allowing teams to focus on critical incidents.
- Standardized Incident Response Playbooks: Develop clear, step-by-step playbooks for ransomware and APT attacks to ensure consistent and efficient responses.
- Integrated Systems: Integrate your SIEM, EDR, threat intelligence, and other security tools to streamline workflows and provide a unified view of security events.
- Real-time Dashboards and Reporting: Provide dashboards for real-time visibility into incidents and facilitate communication across teams.
- Ransomware-Specific Playbooks: Create tailored playbooks addressing different ransomware attack types
- Immutable Backups: Implement immutable backups to safeguard data integrity against ransomware.
- Regular Incident Response Testing: Conduct drills and simulations to evaluate your response capabilities.